

Web Scan – Vulnerability Findings

Target: <https://www.yourmechanic.com/> | Scanner: Pentest-Tools Website Vulnerability Scanner (Light scan) | Date: Aug 06, 2026

1. Scan Summary

Target	https://www.yourmechanic.com/
Scan type	Light
Tests performed	40
Overall risk level	Low
Findings	Low: 1 (Server software/technology found) Info: 1 (Security.txt file is missing)

2. Vulnerability Selected for Review

Finding: Security.txt file is missing

Location: <https://www.yourmechanic.com/.well-known/security.txt>

Severity: Info

Classification: CWE-1188 (Insecure Default Initialization of Resource) — OWASP Top 10 2021: A05, Security Misconfiguration

Note: No CVE number was provided for this finding. This is expected, as this issue relates to a missing configuration file/best practice rather than a specific software vulnerability with an assigned CVE identifier.

3. Description of the Vulnerability

The scan found that the website does not publish a security.txt file at the standard location ([/.well-known/security.txt](https://www.yourmechanic.com/.well-known/security.txt)). This file, defined by RFC 9116, is intended to give security researchers a clear, documented channel for reporting vulnerabilities they discover on a site. Its absence does not itself expose data or allow an attacker to compromise the server, but it does mean that if a researcher finds a genuine security issue, they have no obvious or trusted way of reporting it to the organisation. This can delay the disclosure and remediation of real vulnerabilities, and in some cases may push a well-intentioned researcher toward public disclosure before the organisation has a chance to fix the issue.

4. Recommended Solution / Mitigation

The recommended fix is to implement a security.txt file according to the RFC 9116 standard. In practice, this involves:

- Creating a plain-text file named **security.txt** and publishing it at <https://www.yourmechanic.com/.well-known/security.txt> (the well-known path required by the standard).
- Including a **Contact** field with a monitored email address or web form URL that researchers can use to report vulnerabilities.
- Including an **Expires** field with a future date, so the file is refreshed periodically and does not go stale.
- Optionally adding an **Encryption** field (e.g. a link to a PGP key) so sensitive reports can be sent securely, and a **Policy** field linking to the organisation's responsible-disclosure or bug-bounty policy.
- Keeping the file up to date as contact details or policies change, and monitoring the associated inbox so reports are actioned promptly.

This is a low-effort, low-risk fix: it does not require any code changes to the application itself, only the addition of a static text file to the web server. Implementing it improves the site's defensive posture by giving external researchers a designated, low-friction channel to report issues responsibly, which supports faster detection and remediation of any future vulnerabilities.

As a general practice, it is also recommended to consult official references (OWASP Top Ten, the National Vulnerability Database, the CVE database, and securitytxt.org) and follow vendor or industry best-practice guidance rather than relying on a single fix, since not all vulnerabilities can be resolved with a simple patch.